

AWS Security Agent - AnyCompany CRM Demo Script

Persona

Sarah is a security engineering lead at a mid-size SaaS company. With years of experience securing cloud-native applications, she understands the importance of catching vulnerabilities early. However, coordinating manual design reviews, code audits, and penetration tests across a fast-moving engineering team is time-consuming, inconsistent, and often happens too late — after code has already shipped to production.

Use Case Scenario

Sarah's company recently adopted AWS Security Agent to automate security assessments across their applications. To evaluate the agent's effectiveness, her team built AnyCompany CRM — a full-stack CRM application on AWS that intentionally contains common vulnerabilities: SQL injection, cross-site scripting (XSS), command injection, insecure direct object references (IDOR), and mass assignment.

The CRM serves as a realistic test environment where the team can observe how the Security Agent detects these vulnerabilities through three complementary capabilities — design review, code review, and penetration testing — and provides actionable remediation guidance for each finding.

Solution Details

The AWS Security Agent automates vulnerability detection across the full application lifecycle. Here's how it works:

1. Design Review

- The team uploads architecture and security design documents to the Security Agent console.
- The agent evaluates each document against AWS-managed security requirements (Authorization, Audit Logging, Cryptography, etc.) and custom requirements the team defined (SQL Injection Prevention, XSS Prevention, Command Injection Prevention, IDOR Access Control).
- Each finding includes a detailed comment explaining what the agent detected and specific remediation guidance.

2. Vulnerability Demonstrations

The CRM includes interactive demos that showcase the vulnerabilities the Security Agent detects:

- **SQL Injection & IDOR:** Unsanitized input concatenated into SQL queries; sequential profile IDs accessible without authorization.
- **Cross-Site Scripting (XSS):** Stored, reflected, and DOM-based XSS across multiple pages — including innerHTML injection, attribute-based XSS, and URL parameter reflection.
- **Command Injection:** User input passed directly to system commands via `shell=True`, enabling arbitrary command execution.
- **Mass Assignment:** API accepts unvalidated fields from request bodies, allowing authorship spoofing.

Each demo provides educational context — what happened, how the agent detects it, and sample payloads to try.

3. Penetration Testing

- The team creates a pen test targeting the CRM's deployed URLs in the Security Agent console.
- The agent scans the live application, testing for exploitable vulnerabilities across all endpoint categories.
- Results are categorized by severity (Critical, High, Medium, Low) and tracked across runs, making it easy to verify fixes and detect regressions.

Benefits

Shift-Left Security Design reviews catch architectural vulnerabilities before code is written, reducing remediation cost.

Actionable Remediation Guidance Every finding includes specific, code-level fixes — not just descriptions of the problem.

Custom Security Requirements Teams define requirements tailored to their application's risk profile, ensuring the agent checks for what matters most.

Severity-Based Prioritization Findings are categorized by severity, helping teams focus on the most impactful issues first.

Full Lifecycle Coverage From design review through code analysis to runtime pen testing, the agent covers the entire development lifecycle.

Conclusion

With AWS Security Agent, Sarah's team can continuously assess the security posture of their applications — catching vulnerabilities in design documents, source code, and running applications. The AnyCompany CRM demo showcases this full lifecycle, demonstrating how the agent detects real-world vulnerabilities and provides the guidance teams need to remediate them quickly.